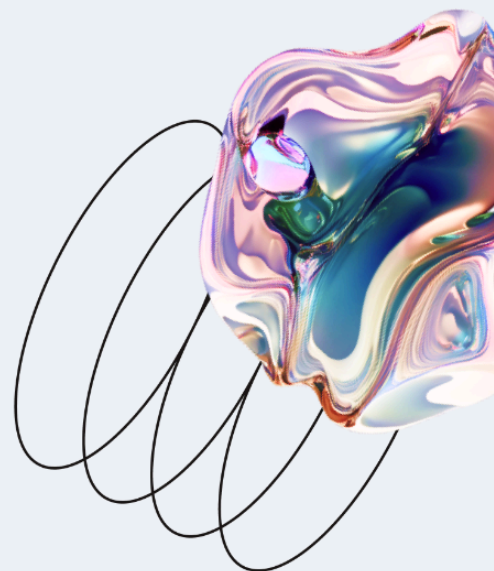




Анализ и оценка защищенности

Основы информационной
безопасности



Оглавление

Введение.....	4
Словарь терминов.....	4
Цели и критерии оценки защищённости.....	5
Варианты анализа и оценки защищённости.....	6
Виды аудита информационной безопасности.....	8
Общие сведения об аудите информационной безопасности.....	8
Непосредственное проведение аудита ИБ.....	10
Выводы по модулю.....	12
Разведка по открытым источникам (OSINT).....	12
Тестирование на проникновение (pentest) и киберучения (cyber exercise).....	14
Тестирование на проникновение.....	14
Выявление известных уязвимостей.....	15
Киберучения.....	16
Выводы по модулю.....	17
Методы анализа защищённости отдельных приложений.....	17
Анализ (инспекция) кода (code review).....	17
Статический анализ (SAST).....	18
Динамический анализ (DAST).....	18
Компонентный анализ и анализ внешних зависимостей (SCA/ OSA).....	19
Фаззинг-тестирование (fuzz testing).....	20
Выводы по модулю.....	20
Выводы.....	20

Дополнительные материалы.....	21
Использованная литература.....	21

Введение

Сегодня мы завершаем курс, посвящённый основам обеспечения информационной безопасности (ИБ), и текущее итоговое занятие – анализ и оценка защищённости.

На этой лекции вы узнаете:

- Какие есть цели и критерии оценки защищённости?
- Какие есть варианты анализа и оценки защищённости?
- Чем отличаются различные виды аудита информационной безопасности?
- Что такое разведка по открытым источникам (OSINT)?
- Чем отличается тестирование на проникновение (pentest) от киберучений (cyber exercise)?
- Какие есть методы анализа защищённости отдельных приложений?

Словарь терминов

Оценка соответствия информационной безопасности организации установленным требованиям – деятельность, связанная с прямым или косвенным определением выполнения или невыполнения в организации установленных требований информационной безопасности ([ГОСТ Р 53114-2008](#)).

Аттестация объекта информатизации – комплекс организационных и технических мероприятий и работ (аттестационных испытаний), в результате которых подтверждается соответствие объекта информатизации требованиям по защите информации в условиях его эксплуатации (адаптировано из [приказа ФСТЭК России](#)).

Аудит информационной безопасности организации – систематический, независимый и документируемый процесс получения свидетельств деятельности организации по обеспечению информационной безопасности и установлению степени выполнения в организации критериев информационной безопасности, а также допускающий возможность формирования профессионального аудиторского суждения о состоянии информационной безопасности организации ([ГОСТ Р 53114-2008](#)).

Свидетельство (доказательство) аудита информационной безопасности организации – запись, изложение фактов или другая информация, которые имеют отношение к критериям аудита информационной безопасности организации и могут быть проверены ([ГОСТ Р 53114-2008](#)).

Критерий аудита информационной безопасности организации – совокупность принципов, положений, требований и показателей действующих нормативных документов, относящихся к деятельности организации в области информационной безопасности ([ГОСТ Р 53114-2008](#)).

Технический контроль эффективности защиты информации (контроль защищённости системы) – контроль эффективности защиты информации (защищённости системы), проводимый с использованием средств контроля, включающий тестирование на проникновение и/или анализ уязвимостей (адаптировано из [ГОСТ Р 57580.1-2017](#) и [Р 50.1.056-2005](#)).

Цели и критерии оценки защищённости

Стоит вспомнить то, что в рамках данного курса мы придерживаемся следующего варианта: понятие *информационной безопасности* применяем к чему-то, например: к организации, системе, приложению или т.п. Соответственно, *анализ и оценку защищённости*, точно так же будем применять к чему-то: к организации, системе или отдельно взятому приложению.

Смоделировав угрозы, выбрав меры защиты и реализовав их с применением технологий и инструментов обеспечения ИБ, в т.ч. криптографических, нам может показаться, что деятельность по обеспечению ИБ завершена. Однако сами по себе эти действия не могут гарантировать, что мы достигли целей обеспечения ИБ. Для проверки того, обеспечивают ли разработанные изначально планы и проведённые по ним мероприятия выполнение установленных требований, и необходима оценка защищённости.

Основной целью оценки защищённости является получение доверия к правильности и эффективности реализации меры защиты, или подтверждение выполнения / невыполнения установленных требований к обеспечению ИБ. В результате оценки выносится положительное или отрицательное заключение.

На практике, предпосылки для анализа и оценки защищённости, можно разделить на следующие группы, обусловленные:

- требованиями нормативных правовых актов и нормативно-методических документов («регуляторные»)
- требованиями локальных нормативных актов (например, системой менеджмента качества, программой внутреннего аудита и т.п.)
- потребностями организации (проектной, продуктовой, маркетинговой и т.п.)

Цели оценки защищённости условно можно разделить на следующие:

- официальное подтверждение выполнения требований (аттестация объекта информатизации, сертификация организации (деятельности), получение допуска (лицензии) к определённой деятельности и т.п.);
- содействие в улучшении системы защиты информации (составная часть контрольных мероприятий (PDCA), идентификация областей потенциального улучшения и т.п.).

Критериями оценки защищённости могут выступать:

- Международные стандарты (ISO/IEC 27001, ISO 22301, PCI DSS и др.).
- Национальные стандарты (ГОСТ Р ИСО/МЭК 27001, ГОСТ Р 57580.1 и др.).
- Отраслевые стандарты (СТО БР ИББС 1.0, СТО Газпром и др.).
- Требования нормативных правовых актов и нормативно-методических документов (приказ ФСТЭК России №№ 17, 21 и др.).
- Требования и указания отраслевых регуляторов.
- Требования локальных нормативных актов (политики, процедуры и др.).
- Отдельные способы реализации угроз (сценарии кибератак).



Формулировка критерия содержит ключевые (смысловые) слова из требования к обеспечению ИБ – глаголы (например, «запретить», «разрешить», «учесть» и т.п.) либо соответствующие им отглагольные существительные (например, «запрет», «разрешение», «учёт» и т.п.). Слова, такие как «обеспечивать», «позволять», «создавать условия для» и т.п., не являются ключевыми (смысловыми), после них нужно искать смысловой глагол (отглагольное существительное).

Варианты анализа и оценки защищённости

Говоря об анализе и оценке защищённости в широком смысле слова, специалист по ИБ должен проанализировать исходные данные и оценить, соответствует ли *что-то чему-то*. Здесь возникают следующие вопросы:

- как это сделать?
- а как делать это регулярно?
- а как делать это системно?

Анализ и оценка защищённости плотно пересекаются, а иногда и подменяют понятия *оценки соответствия ИБ установленным требованиям и оценки эффективности обеспечения ИБ.*

С учётом различных предпосылок, целей и областей регулирования возникло несколько вариантов проведения мероприятий по анализу и оценке защищённости.

Условно можно выделить следующие варианты анализа и оценки защищённости:

- аттестация объекта информатизации по требованиям защиты информации и периодический контроль уровня защиты информации – «регуляторная» активность, в первую очередь[^] в отношении государственных информационных систем [1, 2] (периодичность: не реже одного раза в 2 года)
- оценка эффективности реализованных в рамках системы защиты персональных данных, мер по обеспечению безопасности персональных данных – «регуляторная» активность (на практике зачастую приравнивается к формату аттестационных испытаний) [3, 4] (периодичность: не реже одного раза в 3 года)
- аудит ИБ организации / системы – комплексная «регуляторная» активность или активность, обусловленная локальными нормативными актами или потребностями конкретной организации (периодичность: зачастую ежегодная)
- тестирование на проникновение – практическая (техническая) «регуляторная» активность или активность, обусловленная потребностями конкретной организации (периодичность: зачастую ежегодная)
- выявление известных уязвимостей – практическая «регуляторная» активность или активность, обусловленная потребностями конкретной организации (периодичность: зачастую отсутствует)
- киберучения – активность, обусловленная потребностями конкретной организации:
 - штабные
 - практические(периодичность: зачастую отсутствует)
- анализ безопасности (уязвимостей) отдельных приложений – практическая (техническая) «регуляторная» активность или активность, обусловленная потребностями конкретной организации (периодичность: обусловлена жизненным циклом разработки)
- верификация – «регуляторная» активность (процессы оценки, используемые для подтверждения того, что меры обеспечения системы для системы

реализованы корректно, и их применение является эффективным ([ГОСТ Р ИСО/МЭК ТО 19791-2008](#)))

Здесь же стоит упомянуть предусмотренные ГОСТ Р 53114-2008 [5] *контроль обеспечения ИБ организации* – проверку соответствия обеспечения ИБ в организации требованиям, и *мониторинг ИБ организации* – постоянное наблюдение за процессом обеспечения ИБ в организации с целью установления его соответствие требованиям. Но несмотря на схожесть в определениях, на практике их не рассматривают именно как мероприятия по анализу и оценке защищённости.



Стоит отметить, что, к сожалению, эффективность в разрезе ИБ может восприниматься по-разному. Согласно одному ГОСТ-у, *эффективность защиты информации* – степень соответствия результатов защиты информации цели защиты информации ([ГОСТ Р 50922-2006](#)), т.е. фактически результативность, которую можно проверить с помощью приведённых выше вариантов анализа и оценки защищённости. А согласно другому ГОСТ-у *эффективность обеспечения информационной безопасности* – связь между достигнутым результатом и использованными ресурсами для обеспечения заданного уровня ИБ ([ГОСТ Р 53114-2008](#)), т.е. фактически соотношение результата и понесённых затрат, для оценки которого нужны другие инструменты.

Виды аудита информационной безопасности

Общие сведения об аудите информационной безопасности

Аудит ИБ является самым распространённым вариантом анализа и оценки защищённости, который может применяться как к организации целиком, так и к отдельным её видам деятельности и/или системам.

В зависимости от привлекаемых аудиторов (проверяющих) аудиты ИБ делаться на следующие группы:

- внутренний аудит:
 - аудит первой стороной (проверяющие работники самой аудируемой организации)
- внешний аудит:
 - аудит второй стороной (аудит поставщика работниками организации-заказчика)
 - аудит третьей стороной (сертификационный аудит организации внешними специализированными организациями)

Можно выделить следующие основные принципы проведения аудитов, включая аудиты ИБ [6]:

- честность (выполнять свою работу честно, старательно и ответственно, а также проводить аудит только тогда, когда это позволяет компетентность аудиторов)
- беспристрастность (представлять правдивые и точные отчёты)
- профессиональная осмотрительность (принимать обдуманные решения в любых ситуациях в процессе аудита)
- конфиденциальность (защищать полученную информацию)
- независимость (быть независимыми от деятельности, подлежащей аудиту всегда, где это осуществимо, и во всех случаях действовать независимо от пристрастий и конфликта интересов)
- подход, основанный на свидетельстве (применять соответствующие выборки, свидетельства аудита должны быть проверяемыми)
- риск-ориентированный подход (фокусировать аудит на вопросах, имеющих значение для заказчика аудита)

Область аудита (audit scope) определяет объём и границы аудита ИБ и обычно включает в себя:

- местонахождение (локации):
 - центральный офис
 - центры обработки данных (ЦОД)
 - дополнительные офисы
 - точки/шлюзы взаимодействия
- организационную структуру:
 - ИБ-специалисты
 - куратор ИБ-тематики (если есть)
 - ИТ-специалисты
 - владельцы аудируемых процессов

- юристы и др. специалисты
- виды деятельности и процессы:
 - процессы обработки информации
 - процессы обеспечения ИБ
- ИТ-инфраструктуру (ИС и СрЗИ):
 - обязательные объекты: системы и средства, предназначенные для автоматизации видов деятельности и процессов, подвергающихся аудиту ИБ
 - дополнительные объекты: системы и средства, наличие и/или состояние которых определяют возможность возникновения рисков ИБ
- охватываемый период времени

Фазы аудита ИБ [6]:

- установление контакта с проверяемой организацией:
 - подтвердить каналы взаимодействия
 - подтвердить полномочия на проведение аудита ИБ
 - представить информацию об аудите ИБ
 - согласовать вопросы конфиденциальности
 - согласовать сроки
 - согласовать наличие наблюдателей и сопровождающих
 - решить проблемы в отношении состава группы по аудиту ИБ
- определение возможности проведения аудита ИБ:
 - достаточность информации для планирования и проведения аудита ИБ
 - соответствующее сотрудничество со стороны проверяемой организации
 - наличие необходимого времени и ресурсов для проведения аудита ИБ
- подготовка к проведению аудита ИБ:
 - (предварительный) анализ документированной информации
 - планирование аудита ИБ
 - распределение работы среди членов аудиторской группы
 - подготовка документированной информации для аудита ИБ
- непосредственное проведение аудита ИБ:
 - распределение ролей и обязанностей, сопровождающих и наблюдателей
 - проведение вступительного заседания
 - сбор и проверка информации
 - формирование обнаружений аудита
 - подготовка заключений по аудиту

- проведение заключительного заседания
- подготовка и рассылка отчёта по аудиту ИБ:
- завершение аудита ИБ
- выполнение последующих действий по результатам аудита ИБ

Непосредственное проведение аудита ИБ

В рамках непосредственного проведения аудита ИБ аудиторы осуществляют различные проверки, которые определяют собой объём мероприятий по аудиту ИБ:

- горизонтальные проверки: проверяются отдельные элементы из области аудита ИБ на соответствие *отдельным критериям* аудита ИБ
- вертикальные проверки: проверяются отдельные элементы из области аудита ИБ на соответствие *всем критериям* аудита ИБ
- кросс-проверки: проверяются отдельные элементы из области аудита ИБ *разными способами* на соответствие *одному и тому же* критерию аудита ИБ

В связи с невозможностью за ограниченное время ограниченным числом аудиторов проверить абсолютно все элементы из области аудита ИБ аудиторы используют выборку:

- на основе суждения аудитора (исходя из опыта и компетенции)
- случайный отбор (по таблице случайных чисел)
- статистический или систематический отбор
- комбинация вариантов отбора
- авторские выборки (например: $\sqrt{n}$ от общего числа элементов из области аудита ИБ)

Аудиторы могут использовать различные методы для получения свидетельств:

- проведение интервью
- заполнение проверочных (опросных) листов и вопросников
- проведение анализа документов
- наблюдение за выполнением работы
- получение данных от инструментальных средств

Методы аудита ИБ	Местоположение аудитора	
	На территории	На расстоянии
С взаимодействием людей	Проведение интервью	Проведение интервью через интерактивные средства коммуникации

Методы аудита ИБ	Местоположение аудитора	
	На территории	На расстоянии
	Заполнение проверочных листов с участием персонала	Заполнение проверочных листов с использованием интерактивных средств коммуникации
	Проведение анализа документации с участием представителей	Проведение анализа документации с использованием интерактивных средств коммуникации
	Проведение анализа документации без участия персонала	Проведение анализа документации без использования интерактивных средств коммуникации, без участия персонала
	Наблюдение за выполнением работы без участия персонала. Наблюдение за выполнением работы с помощью технических средств	Наблюдение за выполнением работы с помощью технических средств, обеспечивающих надзор/контроль за производственной деятельностью
	Заполнение аудитором проверочных листов без участия персонала	Заполнение аудитором проверочных листов без участия персонала
	Получение данных от инструментальных средств	Получение данных от инструментальных средств, в т.ч. из общедоступных источников (сети Интернет)

По итогам получения свидетельств аудита ИБ производится оценка. Для отдельных критериев аудита ИБ используются:

- «Бинарные» оценки (выполнено / не выполнено)
- «Градиентные» оценки (выполнено / выполнено частично / не выполнено и т.п.)

Для итоговых оценок:

- отсутствие/наличие замечаний:
 - значительное (major nonconformity): полное или повторяющееся невыполнение установленных критериев аудита ИБ
 - незначительное (minor nonconformity): разовое невыполнение установленных критериев аудита ИБ (отклонение, упущение)
- итоговый показатель (интегральная оценка)
- соотнесение со шкалой оценок

По итогам аудита ИБ оформляется заключение (audit conclusion):

- безусловно положительное
- условно положительное
- отрицательное
- отказ от выражения заключения

Полученные свидетельства, результаты оценок и заключение оформляются в составе отчёта по аудиту ИБ.

 Рекомендации по улучшению не являются обязательной частью отчёта по аудиту ИБ. Стоит отметить, что выработка рекомендаций аудиторами должна соблюдать принципы беспристрастности и независимости.

Выводы по модулю

- Аудит – это универсальный инструмент оценки деятельности
- Аудит ИБ – это самый распространённый вариант анализа и оценки защищённости организаций
- Принципы проведения аудита, направлены на получение объективной и достоверной оценки
- Критерии аудита ИБ – это неотъемлемая часть аудита ИБ, без которой аудит ИБ невозможен
- Область аудита ИБ – это не только ИТ-инфраструктура (системы или СРЗИ)

Разведка по открытым источникам (OSINT)

Разведка по открытым источникам (Open Source Intelligence (OSINT)) является неотъемлемой частью любого из вариантов анализа и оценки защищённости, представляет собой поиск и сбор информации об объекте, полученной из общедоступных источников, их классификация и анализ.

В недалеком прошлом к общедоступным источникам относилась:

- информация из СМИ и других печатных источников (телефонные справочники и т.д.)
- интервьюирование, телефонные звонки, «наведение справок» (тонкая грань с социальной инженерией),

сейчас же это информационно-телекоммуникационные сети, включая сеть Интернет.

К основным отправным точкам для OSINT можно отнести:

- наименование организации
- имя человека/никнейм, логин в социальных сетях
- адрес электронной почты, номер телефона
- наименование/дата события (мероприятия)

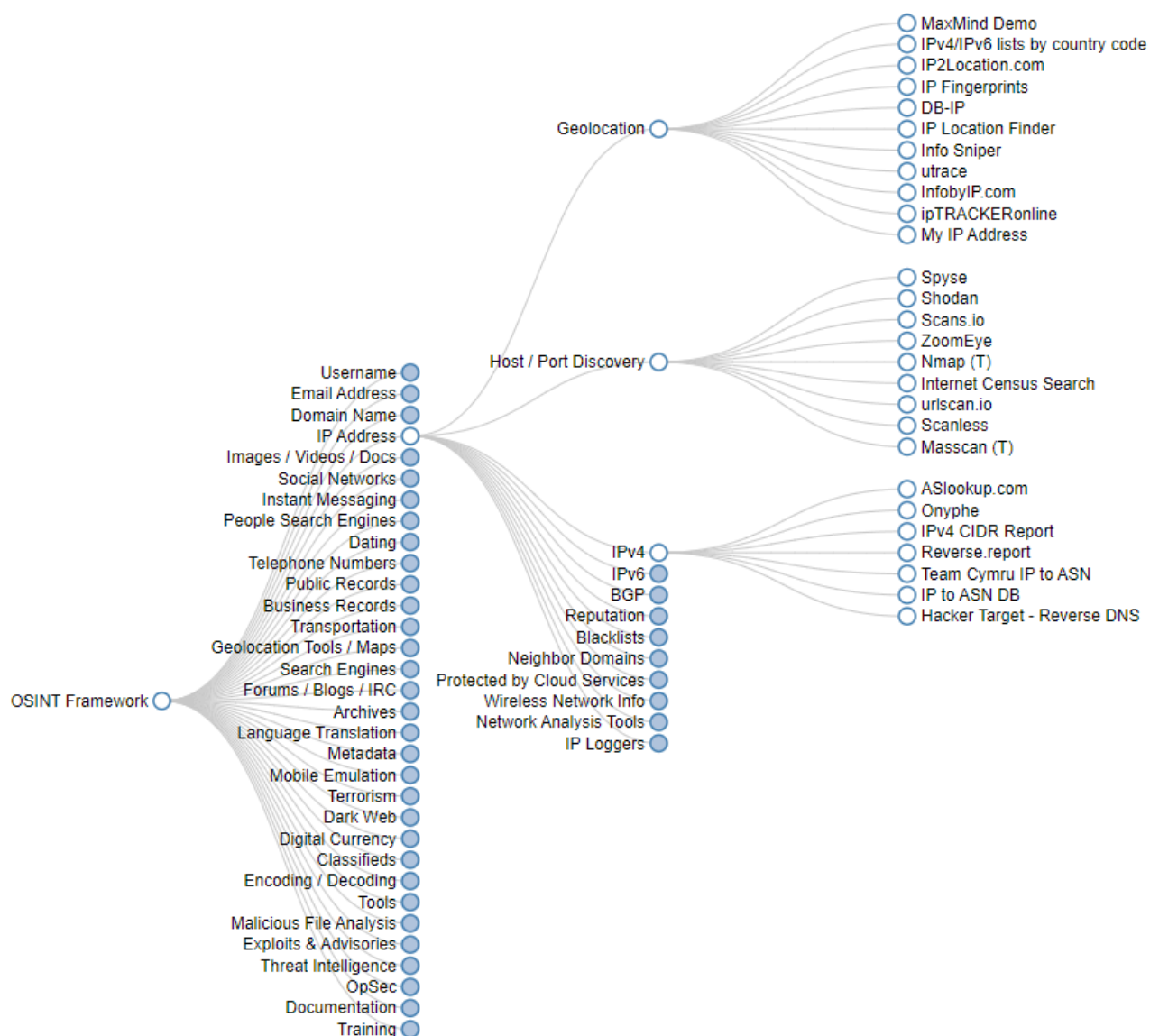
Методы разведки по открытым источникам условно можно разделить на следующие:

- активные: прямое взаимодействие с объектом (например, просмотр корпоративного веб-сайта, сканирование сетевого периметра и т.п.)
- пассивные: отсутствие прямого взаимодействия с объектом (например, поисковых системах Google/Yandex, анализ вакансий организации, анализ материалов мероприятий с участием объекта и т.п.)



В отношении пассивных методов разведки с использованием поисковой системы Google возникло отдельное направление, получившее название «Google Hacking» («Google Dorking»).

Наглядно с методами и инструментами OSINT в зависимости от анализируемых объектов можно познакомиться с использованием онлайн сервиса [OSINT Framework](#). Предлагаемые сервисом варианты для объекта – IP-адрес, приведены ниже:



Тестирование на проникновение (pentest) и киберучения (cyber exercise)

Тестирование на проникновение

Тестирование на проникновение является основным практически ориентированным вариантом анализа и оценки защищённости.

Условно можно выделить следующие форматы проведения тестирования на проникновение:

- «белый ящик» (black box): команда пентестеров имеет все необходимые сведения об объекте
- «серый ящик» (gray box): команда пентестеров имеет ограниченные сведения об объекте (исходные данные)
- «чёрный ящик» (white box): команда пентестеров имеет минимальные сведения об объекте (исходные данные), уточняет и дополняет их методами OSINT

Тестирование на проникновение включает в себя следующие направления исследований [7]:

- оценка защищённости сетевого периметра, сетевых устройств и протоколов
- оценка защищённости беспроводных сетей
- оценка защищённости веб-приложений
- оценка защищённости операционных систем
- оценка защищённости систем управления базами данных (СУБД)
- оценка защищённости средств виртуализации
- оценка защищённости специализированных банковских приложений
- оценка защищённости мобильных устройств

Вне зависимости от выбранного формата и направления можно выделить следующие фазы тестирования на проникновение [8]:

- планирование тестирования
- разработка тестов
- проведение тестирования
- разработка отчётности по результатам тестирования

Разработка тестов и проведение тестирования базируется на моделях Cyber Kill Chain® и MITRE ATT&CK®.

Альтернативные фазы тестирования на проникновение от EC-Council в рамках курса «Certified Ethical Hacker (CEH)», который многие ИБ-специалисты считают де-факто базовым стандартом по тестированию на проникновение включают в себя:

- разведку, включая OSINT
- сканирование систем
- получение доступа
- закрепление в системе

- сокрытие следов

Достоинствами тестирования на проникновение как варианта анализа и оценки защищённости являются:

- высокая достоверность
- наглядность получаемых результатов

Недостатками тестирования на проникновение являются:

- высокие требования к квалификации исполнителя (способность команды пентестеров воспроизводить только действия нарушителя, равного или уступающего по квалификации)
- низкая степень автоматизации

Выявление известных уязвимостей

Данный вариант анализа и оценки защищённости может являться составной частью тестирования на проникновение или быть самостоятельным мероприятием. Он не требует наличия у исполнителя специальных навыков и допускает полную автоматизацию за счёт применения сканеров безопасности (например, Nessus, OpenVAS, XSpider, MaxPatrol VM, RedCheck и др.). Подробнее про российские решения можно прочитать в [статье](#).

Известные уязвимости могут быть выявлены следующими способами:

- идентификацией наименований и версий программного обеспечения и поиском в базах данных известных для них уязвимостей
- запуском тест-программ (эксплойтов), воспроизводящих в полном объёме или частично выполнение кибератак с использованием известных уязвимостей

Достоинствами выявления известных уязвимостей как варианта анализа и оценки защищённости являются:

- высокая достоверность сведений о выявленных уязвимостях при использовании формата «белого ящика»
- низкие требования к квалификации исполнителя
- высокая степень автоматизации
- воспроизводимость исследования

Недостатками выявления известных уязвимостей являются:

- низкая достоверность сведений о выявленных уязвимостях при использовании формата «чёрного ящика»
- возможность сбоев и отказов в функционировании программного обеспечения при проведении исследования с использованием формата «чёрного ящика»
- необходимость предоставления привилегированного доступа при использовании формата «белого ящика»

Киберучения

Киберучения – это относительно новый вариант анализа и оценки защищённости, делающий акцент на анализ и оценку процессов (процедур) реагирования на инциденты ИБ.

Цели киберучений:

- получение оценки процессов реагирования на инцидент ИБ
- определение объективных и актуальных направлений совершенствования Центров мониторинга ИБ (SOC-ов)

Форматы киберучений:

- штабные киберучения:
 - максимально комфортный (игровой) формат (низкий уровень стресса)
 - все участники знают, что это учения
 - основная подготовка: организационная
- практические киберучения:
 - максимально приближенный к реальности формат (высокий уровень стресса)
 - минимальное число участников знает, что это учения
 - основная подготовка: техническая

Фазы киберучений:

- организационная и/или техническая подготовка к киберучениям
- активная фаза киберучений, в т.ч. непрерывный контроль ситуации со стороны организаторов
- действия после киберучений (lessons learned)

Достоинствами киберучений как варианта анализа и оценки защищённости являются:

- высокая наглядность
- оперативность реализации (дни – часы)

Недостатками киберучений являются:

- нахождение времени для участия в активной фазе киберучений ряда участников, в т.ч. ТОП-менеджмента
- узкая направленность (отдельные способы реализации угроз (сценарии кибератак))



Популярность киберучений обусловлена высокой наглядностью мероприятия и возможностью участия в нём не только ИБ-специалистов, особенно ТОП-менеджеров. По итогам появляется возможность маркетингового продвижения организации и/или регулятора в области обеспечения кибербезопасности.

Выводы по модулю

- Существует несколько вариантов практически ориентированных вариантов анализа и оценки защищённости – понимайте их достоинства и недостатки
- Используйте наиболее удобный Вам вариант анализа и оценки защищённости
- В анализе и оценке защищённости важна регулярность

Методы анализа защищённости отдельных приложений

Анализ (инспекция) кода (code review)

Анализ (инспекция) исходного кода отдельных приложений проводится вручную путём просмотра, анализа и оценки кода специалистом, отличным от его автора-разработчика.

Оценка кода может включать в себя [7]:

- оценку соответствия разработанного кода требованиям, предъявляемым к структурированию и оформлению кода, именованию объектов, разделению на модули, использованию специальных средств обеспечения качества кода, предусмотренных используемыми языками программирования и средствами разработки
- оценку полноты и качества документирования кода, включая документирование заголовков программных модулей, прототипов функций и структур данных, комментарии к выполнению существенных операций
- оценку соответствия алгоритмов, реализованных в исходном коде, программной документации, в т.ч. выявление явных недекларированных возможностей (программных закладок), ошибок программного кода, попыток запутывания (обфускации) программного кода и использования иных приемов, затрудняющих проведение контроля



Методы эффективного анализа (инспекции) исходного кода включают двойное чтение: сначала понять общую структуру, запомнить основные обозначения и соглашения, а затем читать снова, выявляя дефекты, несоответствия.

Статический анализ (SAST)

Статический анализ кода отдельных приложений (Static Application Security Testing (SAST)) проводится с использованием автоматизированных средств (программных инструментов).

Статический анализ реализуется без реального запуска исследуемого приложения, фактически это формат «белого ящика».

Статический анализ направлен на идентификацию потенциально опасных фрагментов кода, включая [7]:

- вызовов функций, методов, процедур (далее – функции) с передачей им в качестве аргументов данных, вводимых пользователем или принимаемых из внешних источников
- текстов функций преобразования форматов данных
- вызовов системных функций и функций обеспечения ИБ, в т.ч. функций обеспечения ИБ операционной системы и специализированных технических защитных мер, функций ввода/вывода, управления памятью и системными ресурсами

- текстов функций, осуществляющих проверку прав доступа и принятие решений, основанных на значениях атрибутов безопасности
- текстов функций, самостоятельно реализующих функциональность обеспечения ИБ, в т.ч. криптографические функции, аутентификацию пользователей и проверку прав доступа, генерацию данных мониторинга ИБ
- текстов функций, предусматривающих установление соединения с внешними компонентами с передачей им аутентификационных данных
- текстов обработчиков ошибок и исключений

Динамический анализ (DAST)

Динамический анализ кода отдельных приложений (Dynamic Application Security Testing (DAST)) проводится с использованием специализированных автоматизированных средств (программных инструментов).

Динамический анализ реализуется путём выполнения или эмуляции выполнения приложения на определённой совокупности наборов тестовых исходных данных. Перед выполнением или в процессе выполнения приложение иногда инструментируется путём дополнения её функциями трассировки выполнения для задания и контроля инвариантов, предусловий, постусловий и др.

Динамический анализ направлен на идентификацию потенциально опасных вариантов исполнения кода, включая [7]:

- исследование особенностей исполнения потенциально опасных функций при задании заведомо некорректных аргументов
- построение динамических путей исполнения программы и идентификацию точек принятия решений, существенных для выполнения функций обеспечения ИБ
- поиск чувствительной информации в оперативной памяти и в аргументах функций
- исследование особенностей исполнения программы при типовых атаках (переполнение буфера, внедрение SQL-операторов в данные, используемые для формирования запросов к СУБД)

Компонентный анализ и анализ внешних зависимостей (SCA/ OSA)

Компонентный (композиционный) анализ и анализ внешних зависимостей отдельных приложений (Software Composition Analysis (SCA) / (Open Source Analysis (OSA))) проводится с использованием специализированных автоматизированных средств (программных инструментов).

Компонентный анализ реализуется путём анализа кода отдельных приложений или совокупности приложений в произвольной форме (репозиторий, директория с файлами, Docker-образ, бинарник и т.п.).

Компонентный анализ направлен на идентификацию потенциально опасных (несовместимых) компонентов, включая:

- выявление лицензионного состава open source и коммерческих компонентов, оценку совместимости лицензий самого приложения и компонентов между собой (лицензионная чистота)
- выявление прямых зависимостей (тех, которые явно указываются разработчиком) и транзитивных зависимостей, анализ цепочек вызовов зависимостей
- выявление известных уязвимостей для компонентов по базам уязвимостей (например, National Vulnerability Database, Github Advisory и др.)

Фаззинг-тестирование (fuzz testing)

Фаззинг-тестирование отдельных приложений (fuzz testing) проводится с использованием специализированных автоматизированных средств (программных инструментов) – фаззера, который автоматически вводит данные в приложение и обнаруживает ошибки.

Фаззинг-тестирование реализуется путём выполнения или эмуляции выполнения приложения на определённой совокупности наборов тестовых исходных данных, которые изначально являются неправильными, неожиданными приложением и/или случайными.

Фаззинг-тестирование направлено на идентификацию потенциально опасных вариантов исполнения кода, включая:

- переполнение буфера

- выход за границы массива
- ошибки сегментации
- отказ в обслуживании
- бесконечный цикл или бесконечная рекурсия
- большое потребление ресурсов памяти и/или процессора
- «состояние гонки»
- деление на 0

Выводы по модулю

- Существует несколько вариантов анализа защищённости отдельных приложений, на практике их комбинируют и учитывают в цикле CI/CD
- Большинство вариантов требуют применения специализированных автоматизированных средств (программных инструментов), которые должны учитывать используемые Вами языки разработки и среды разработки и сборки
- В анализе и оценке защищённости отдельных приложений важна непрерывность с учётом SDLC

Выводы

- Анализ и оценка защищённости являются неотъемлемой частью обеспечения ИБ, но при этом являются отдельным направлением (специализацией) в области обеспечения ИБ
- Существуют различные варианты анализа и оценки защищённости, имеющие свои «драйверы» и области применения
- Зачастую мероприятия по анализу и оценке защищённости требуют привлечения независимых профессиональных специалистов («сторонний взгляд»)
- Результаты анализа и оценки защищённости должны служить входными данными для пересмотра и совершенствования систем обеспечения ИБ

Дополнительные материалы

1. Книга «The Hacker Playbook 3 Practical Guide To Penetration Testing», Петер Ким, 2018.
2. Книга «Аудит безопасности информационных систем», Никита Скабцов, 2018.

3. ГОСТ Р ИСО 19011-2021 «[Оценка соответствия. Руководящие указания по проведению аудита систем менеджмента](#)».
4. Статья «[OSINT или разведка по открытым источникам](#)».
5. Статья «[Сканирование уязвимостей. Глава из книги «Kali Linux. Тестирование на проникновение и безопасность](#)».
1. Статья «[Виды Application Security Testing. Как не запутаться среди SAST, DAST и IAST](#)».

Использованная литература

1. [Требования о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах](#), утв. приказом ФСТЭК России от 11 февраля 2013 года N 17.
2. [Порядок организации и проведения работ по аттестации объектов информатизации на соответствие требованиям о защите информации ограниченного доступа, не составляющей государственную тайну](#), утв. приказом ФСТЭК России от 29 апреля 2021 г. N 77.
3. [Состав и содержание организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных](#), утв. приказом ФСТЭК России от 18 февраля 2013 г. N 21.
4. [Информационное сообщение ФСТЭК России от 15 июля 2013 г. N 240/22/2637](#).
5. ГОСТ Р 53114-2008 «[Защита информации. Обеспечение информационной безопасности в организации. Основные термины и определения](#)».
6. ГОСТ Р ИСО 19011-2021 «[Оценка соответствия. Руководящие указания по проведению аудита систем менеджмента](#)».
7. Рекомендации в области стандартизации Банка России РС БР ИББС-2.6-2014 «[Обеспечение информационной безопасности организаций банковской системы Российской Федерации. Обеспечение информационной безопасности на стадиях жизненного цикла автоматизированных банковских систем](#)»

8. ГОСТ Р 58143-2018 «[Информационная технология. Методы и средства обеспечения безопасности. Детализация анализа уязвимостей программного обеспечения в соответствии с ГОСТ Р ИСО/МЭК 15408 и ГОСТ Р ИСО/МЭК 18045. Часть 2. Тестирование проникновения](#)».